

ENCUESTA INTEGRAL DE EVALUACIÓN DE CIBERSEGURIDAD

CRA-Cyber: Cuestionario de Riesgo y Análisis de Capacidades

Versión: 2.1

Fecha de emisión: Enero 2026

Duración estimada: 45-60 minutos

Confidencialidad: Datos anonimizados y protegidos conforme GDPR

INSTRUCCIONES GENERALES

Esta encuesta ha sido diseñada para evaluar de forma exhaustiva y rigurosa la madurez de ciberseguridad de su organización en seis dimensiones críticas:

1. Caracterización Organizacional — Contexto empresarial y regulatorio
2. Gestión de Vulnerabilidades — Identificación, evaluación y remediación de debilidades
3. Pruebas de Penetración — Evaluación ofensiva de controles de seguridad
4. Gestión de Información y Eventos de Seguridad (SIEM) — Detección y respuesta a incidentes
5. Capacitación en Seguridad — Concienciación y competencias del personal
6. Indicadores de Madurez y ROI — Cuantificación de costes y beneficios

Nota sobre el tono: Reconocemos que las encuestas sobre ciberseguridad pueden resultar abrumadoramente técnicas. Hemos procurado mantener un equilibrio entre rigor metodológico y accesibilidad, incluyendo notas aclaratorias con ligero toque irónico donde conveniente. La seguridad es seria, pero la comunicación clara sobre seguridad no tiene por qué serlo. ✓

MÓDULO 1: CARACTERIZACIÓN ORGANIZACIONAL

P1.1 — Información General de la Organización

¿Cuál es el sector industrial principal de su organización?

- ☐ Servicios Financieros (Banca, Seguros, Mercados de Valores)
- ☐ Salud y Asistencia Sanitaria (Hospitales, Clínicas, Farmacias)
- ☐ Energía (Producción, Distribución, Redes Inteligentes)
- ☐ Transporte (Aéreo, Ferroviario, Carretera, Marítimo, Público Urbano)
- ☐ Suministro de Agua y Saneamiento
- ☐ Telecomunicaciones e Infraestructura Digital
- ☐ Administración Pública (Central, Autonómica, Local)
- ☐ Educación e Investigación
- ☐ Manufactura e Industria (Incluida Crítica)
- ☐ Comercio Minorista y Distribución
- ☐ Tecnología de la Información y Servicios Digitales
- ☐ Medios de Comunicación y Entretenimiento
- ☐ Otro (describir): _____

P1.2 — Tamaño Organizacional

¿Cuántos empleados tiene su organización en la actualidad?

- ☐ Microempresa (1-9 empleados)
- ☐ Pequeña empresa (10-49 empleados)
- ☐ Mediana empresa (50-249 empleados)
- ☐ Empresa grande (250-999 empleados)
- ☐ Gran empresa (1.000-4.999 empleados)
- ☐ Muy gran empresa (≥ 5.000 empleados)

P1.3 — Exposición de Datos y Criticidad Operativa

¿Cuál es la clasificación de datos que procesa principalmente su organización?

- ☐ No sensibles o públicos (web pública, contenido general)
- ☐ Moderadamente sensibles (datos internos, información comercial no crítica)
- ☐ Sensibles (datos personales de clientes, registros financieros)
- ☐ Altamente sensibles (datos de salud, información genética, datos biométricos)
- ☐ Críticos para operación nacional (infraestructura crítica, defensa, operador esencial)
- ☐ Múltiples clasificaciones; combinar según volumen

¿Cuál sería el impacto de una interrupción de 24 horas de sus sistemas IT?

- ☐ Mínimo (operación continúa con procesos manuales)
- ☐ Moderado (degradación de servicios, incomodidad operativa)
- ☐ Alto (incapacidad de operar, pérdidas económicas significativas)
- ☐ Crítico (riesgo para vidas, incumplimiento legal inmediato)
- ☐ Existencial (la organización no puede funcionar sin IT)

P1.4 — Infraestructura y Distribución Geográfica

¿Cuál es la topología primaria de su infraestructura IT?

- ☐ Completamente en el sitio (On-premises, data center propio)
- ☐ Parcialmente en el sitio, parcialmente en cloud (Infraestructura Híbrida)
- ☐ Completamente en cloud público (AWS, Azure, Google Cloud)
- ☐ Cloud privado (infraestructura dedicada de proveedor)
- ☐ Distribuida / Edge (computación descentralizada, múltiples centros de datos)
- ☐ Modelo de composición múltiple (describir): ____

¿En cuántas jurisdicciones geográficas operan sus sistemas críticos?

- ☐ Una (País de domicilio únicamente)
- ☐ 2-5 (Región europea o continental)
- ☐ 6-15 (Múltiples continentes, pero cobertura limitada)
- ☐ 16+ (Operación global distribuida)

P1.5 — Marco Regulatorio Aplicable

¿Cuáles de las siguientes normativas regulatorias le son APLICABLES a su organización?

(Marque todas las que apliquen)

- ☐ GDPR (Reglamento General de Protección de Datos) — Procesamiento de datos personales de residentes UE
- ☐ NIS2 (Directiva de Redes e Información de Seguridad) — Operador de servicio esencial o proveedor importante
- ☐ ENS (Esquema Nacional de Seguridad) — Organismo público español o infraestructura crítica
- ☐ DORA (Digital Operational Resilience Act) — Sector financiero, seguros, servicios pagos
- ☐ HIPAA — Datos de salud (USA), o equivalente regional
- ☐ PCI-DSS — Procesamiento de tarjetas de pago
- ☐ LSSI-CE — Servicios de la Sociedad de la Información (España)
- ☐ ISO 27001/27002 — Certificación adoptada internamente
- ☐ NIS1 (Directiva anterior) — En transición hacia NIS2
- ☐ CMMC 2.0 — Contratista del Ministerio de Defensa (DoD USA)
- ☐ Otra regulación sectorial (describir): ____

¿Cuál es su estado de cumplimiento esperado para NIS2? (Transposición esperada Q1 2026)

- ☐ Completamente alineado; presupuesto y roadmap aprobados
- ☐ Parcialmente preparado; identificados gaps pero sin plan detallado
- ☐ En fase de evaluación inicial
- ☐ No hemos iniciado transposición aún
- ☐ No aplica (no somos operador esencial o proveedor importante)

MÓDULO 2: GESTIÓN DE VULNERABILIDADES

P2.1 — Proceso de Descubrimiento de Vulnerabilidades

¿Realiza su organización escaneo automático de vulnerabilidades?

- ☐ No; sin escaneo formalizado
- ☐ Sí, pero de forma ad hoc (sin cadencia definida)
- ☐ Sí, mensualmente
- ☐ Sí, semanalmente
- ☐ Sí, continuamente (al menos diario)

¿Qué herramientas de escaneo utiliza? (Enumere las principales):

Herramienta	Dominio Escaneado	Frecuencia
Ej. Nessus	Red + Endpoints	Semanal

P2.2 — Alcance del Escaneo de Vulnerabilidades

¿Qué áreas de su infraestructura están cubiertas por escaneo de vulnerabilidades?

Área	Cobertura (%)	Nota
Redes internas	___%	Incluir: routers, switches, firewalls
Servidores Linux/Unix	___%	Incluir: web, BD, aplicación
Servidores Windows/Active Directory	___%	Domain controllers, servidores miembro
Aplicaciones web internas	___%	Aplicaciones corporativas, portales
Aplicaciones web externas (internet-facing)	___%	Sitios públicos, APIs
Dispositivos IoT/OT	___%	Sensores, PLCs, SCADA
Infraestructura cloud (IaaS/PaaS)	___%	Máquinas virtuales, contenedores, serverless
Endpoints (PCs, laptops, dispositivos móviles)	___%	Incluir BYOD si aplica
Proveedores terceros / Supply chain	___%	Evaluación de ecosistema

Descripción: Si un área no está cubierta, ¿por qué? (Recursos, complejidad, riesgo aceptado, etc.)

P2.3 — Metodología de Priorización de Vulnerabilidades

¿Qué metodología utiliza para priorizar vulnerabilidades identificadas?

- ☐ No tenemos proceso formal; se remedian en orden de descubrimiento
- ☐ Solo por severidad CVSS (Common Vulnerability Scoring System)
- ☐ Por CVSS + disponibilidad de parche
- ☐ Por CVSS + EPSS (Exploit Prediction Scoring System)
- ☐ Por CVSS + EPSS + criticidad de activo + contexto de negocio
- ☐ Otro (describir): _____

Explicación: EPSS mide probabilidad real de explotación (0-100%); CVSS mide severidad teórica (0-10). Idealmente, ambas se usan: una vulnerabilidad con CVSS alto pero EPSS bajo se remedia más lentamente que una con ambas altas.

P2.4 — Gestión de Activos y Línea Base

¿Dispone de un inventario actualizado de activos de IT?

- ☐ No; sin inventario formalizado
- ☐ Sí, manual (hojas de cálculo, documentos)
- ☐ Sí, parcialmente automático (CMDB o herramienta de gestión)
- ☐ Sí, completamente automático (descubrimiento continuo)

¿Con qué frecuencia se actualiza su inventario de activos?

- ☐ Anualmente
- ☐ Semestralmente
- ☐ Trimestralmente
- ☐ Mensualmente
- ☐ Continuamente (en tiempo real)

P2.5 — Evaluación de Riesgos Vinculada a Vulnerabilidades

¿Realiza su organización evaluaciones formales de riesgo de vulnerabilidades?

- ☐ No; sin evaluación formal de riesgos
- ☐ Sí, anualmente como mínimo
- ☐ Sí, semestralmente
- ☐ Sí, trimestralmente
- ☐ Sí, continuamente integrada en programa de vulnerabilidades

¿Qué metodología usa para cuantificar riesgo residual?

- ☐ Cualitativa (Bajo / Medio / Alto)
- ☐ Semicuantitativa (puntuación 1-10, matriz de impacto × probabilidad)
- ☐ Cuantitativa (pérdida esperada anual en €, FAIR, ALE)
- ☐ Combinada (cualitativa + cuantitativa según criticidad)

P2.6 — Remediación y Seguimiento

¿Cuál es el tiempo promedio de remediación desde identificación hasta validación?

Severidad CVSS	Tiempo Objetivo (SLA)	Tiempo Real Promedio
Crítica (9.0-10.0)	Describir	
Alta (7.0-8.9)	Describir	
Media (4.0-6.9)	Describir	
Baja (0.1-3.9)	Describir	

¿Realiza validación de remediación?

- ☐ No; asumimos que el parche/cambio remedia
- ☐ A veces; muestreo aleatorio
- ☐ Sí, siempre; re-escaneo post-remediación
- ☐ Sí, con automatización; validación continua

P2.7 — Vulnerabilidades No Remediables

¿Cómo gestiona vulnerabilidades que no pueden ser remediadas? (Ej.: no hay parche disponible, parche rompe funcionalidad, riesgo aceptado)

- ☐ No tenemos proceso formalizado
- ☐ Aceptación ad hoc sin documentación
- ☐ Documentamos la aceptación pero sin revisión periódica
- ☐ Aplicamos controles compensatorios documentados y revisamos cada 6 meses
- ☐ Aplicamos controles compensatorios, documentamos y revisamos cada trimestre; auditoría anual

MÓDULO 3: PRUEBAS DE PENETRACIÓN (PENTESTING)

P3.1 — Frecuencia y Alcance del Pentesting

¿Realiza su organización pruebas de penetración regulares?

- ☐ No; sin pentesting formalizado
- ☐ Sí, ocasionalmente (cada 2+ años)
- ☐ Sí, anualmente
- ☐ Sí, semestralmente
- ☐ Sí, trimestralmente o más frecuentemente

¿Quién conduce los pentests?

- ☐ Personal interno únicamente
- ☐ Principalmente proveedor externo (consultora acreditada)
- ☐ Combinado: personal interno + auditoría externa anual
- ☐ Red team interno + pentesting externo para diferentes áreas

P3.2 — Tipos de Pruebas Realizadas

¿Qué tipos de pruebas de penetración ejecuta regularmente?

Tipo de Pentest	Frecuencia	Scope	Nota
Red-based (firewalls, IPS, detectabilidad de red)	___/año	___	
Host-based (endpoints, servidores, sistemas operativos)	___/año	___	
Web-based (aplicaciones, APIs, inyecciones)	___/año	___	
Inalámbrica (WiFi, Bluetooth, redes móviles)	___/año	___	
Physical security (acceso físico, tailgating)	___/año	___	
Social Engineering / Phishing	___/año	___	
OT/ICS (sistemas industriales, SCADA, PLCs)	___/año	___	
Cloud/API (infraestructura en la nube, integraciones)	___/año	___	

P3.3 — Metodología y Estándar de Pentesting

¿Qué estándar metodológico sigue el pentesting?

- ☐ Ad hoc; sin metodología documentada
- ☐ OWASP Testing Guide (aplicaciones web)
- ☐ NIST SP 800-115 (pruebas técnicas)
- ☐ PTES (Penetration Testing Execution Standard)
- ☐ CREST / CHECK metodología
- ☐ Estándar propietario del consultor
- ☐ Otro (describir): _____

P3.4 — Niveles de Información al Pentester (Engagement Model)

¿Realiza pruebas con diferentes niveles de conocimiento previo?

- ☐ No; todas con el mismo modelo
- ☐ Sí; mezclamos:
- ☐ Black-box (sin información previa; simula atacante externo)
- ☐ Gray-box (información limitada; conocimiento de infraestructura alto nivel)
- ☐ White-box (acceso total; conocimiento completo; focaliza en lógica de negocio)

P3.5 — Maturity Modelo del Programa de Pentesting

¿Cuál es el nivel de madurez de su programa de pentesting?

- ☐ Nivel 1 (Foundation): Pentesting ad hoc, sin proceso documentado, sin seguimiento formal de hallazgos
- ☐ Nivel 2 (Emerging): Pentesting anual, proceso básico documentado, seguimiento de críticos solamente
- ☐ Nivel 3 (Established): Pentesting regular (semestral o más), plan documentado, seguimiento de todos los hallazgos, métricas básicas (MTTF, tasa remediación)
- ☐ Nivel 4 (Dynamic): Pentesting frecuente (trimestral/continuo), integrado en SDLC/DevOps, automatización de seguimiento, métricas avanzadas (MTTR, defect density, trending)
- ☐ Nivel 5 (Optimized): Pentesting continuo, red team persistente, inteligencia de amenazas integrada, automatización total, mejora continua proactiva

P3.6 — Remediación de Hallazgos de Pentesting

¿Cuál es el tiempo promedio desde hallazgo hasta validación de remediación?

Severidad	Tiempo Objetivo (SLA)	Tiempo Real (promedio)
Crítica (Ejecución código remoto, bypass autenticación)		
Alta (Acceso no autorizado, escalada privilegios)		
Media (Información disclosure, debilidad lógica)		
Baja (Configuración débil, recomendación defensiva)		

P3.7 — Seguimiento de Tendencias en Pentesting

¿Realiza análisis de tendencias en resultados de pentesting?

- ☐ No; cada reporte se trata aisladamente
- ☐ Sí; comparamos resultados históricos año a año
- ☐ Sí; mantenemos métricas trimestrales (tasa remediación, nuevos hallazgos, regresiones)
- ☐ Sí; tracking continuo con dashboards de trending

MÓDULO 4: GESTIÓN DE INFORMACIÓN Y EVENTOS DE SEGURIDAD (SIEM)

P4.1 — Arquitectura y Cobertura SIEM

¿Dispone su organización de una solución SIEM?

- ☐ No; sin SIEM centralizado
- ☐ Sí, parcialmente (cobertura limitada a departamentos o sistemas críticos)
- ☐ Sí, cobertura completa de infraestructura corporativa
- ☐ Sí, incluida infraestructura en cloud, endpoints y OT

¿Cuál es la solución SIEM utilizada?

- ☐ Splunk
- ☐ Elastic Stack (ELK)
- ☐ IBM QRadar
- ☐ Microsoft Sentinel (Azure)
- ☐ Google Chronicle
- ☐ Sumo Logic
- ☐ Solución de proveedor cloud nativa
- ☐ Solución de código abierto (describir): _____
- ☐ Desarrollo interno
- ☐ Múltiples SIEMs en arquitectura federada

P4.2 — Cobertura de Fuentes de Datos

¿Qué fuentes de datos están integradas en su SIEM?

Fuente	Integrada (Sí/No)	Fuente	Integrada (Sí/No)
Firewalls		Servidores web (logs de acceso)	
IDS/IPS		Aplicaciones (logs de aplicación)	
Proxies / URL filtering		Bases de datos (audit logs)	
VPN		Sistemas de gestión de identidad (Active Directory, IAM)	
Antimalware / Antivirus		Cloud infrastructure (AWS CloudTrail, Azure logs)	
EDR (Endpoint Detection & Response)		Sistemas OT/ICS	
DHCP / DNS		Herramientas de auditoría (Tripwire, Auditbeat)	

P4.3 — Capacidad de Detección de Amenazas

¿Cuál es el nivel de sofisticación de la detección en su SIEM?

- ☐ Básica: Alertas por firmas y reglas simples de correspondencia
- ☐ Intermedia: Correlación de eventos (múltiples eventos – incidente), detección por anomalías de umbral
- ☐ Avanzada: Machine learning / behavioral analytics, detección de anomalías estadística
- ☐ Experta: IA / modelos comportamentales avanzados, integración con threat intelligence, investigación asistida

¿Realiza análisis de inteligencia de amenazas integrado con detección SIEM?

- ☐ No
- ☐ Sí, feeds de amenazas públicas (IP/URL/dominio reputados)
- ☐ Sí, feeds comerciales (CrowdStrike, Mandiant, Recorded Future)
- ☐ Sí, análisis interno de amenazas + feeds externos
- ☐ Sí, threat intelligence continua con enriquecimiento automático

P4.4 — KPIs de Detección SIEM

¿Cuál es su performance actual en detección?

KPI	Valor Actual	Objetivo
MTTD (Mean Time To Detect)	___ minutos	___ minutos
Cobertura de activos críticos	___%	100%
Tasa de verdaderos positivos (True Positive Rate)	___%	>70%
Tasa de falsos positivos	___%	<15%
Alert-to-Incident ratio	1:___	1:<20
Logs procesados por día	___ millones	
Retención de logs	___ días	___ días

P4.5 — Integración con Respuesta a Incidentes

¿Cómo se integra el SIEM con procesos de respuesta a incidentes?

- ☐ Manual; analistas revisan alertas y crean tickets manualmente
- ☐ Semi-automatizado; algunos scripts para casos comunes
- ☐ Automatizado parcialmente; playbooks para incidentes críticos
- ☐ Automatizado avanzado; SOAR (Security Orchestration, Automation, Response) integrado

¿Cuál es el tiempo promedio de respuesta desde alerta confirmada a contención?

Severidad	MTTR Objetivo (SLA)	MTTR Real (promedio)
Crítica		
Alta		
Media		
Baja		

P4.6 — Modelos de Alertas y Reglas de Correlación

¿Cuántas reglas de correlación activas tiene configuradas su SIEM?

- ☐ <50 (Configuración mínima)
- ☐ 50-150 (Configuración estándar)
- ☐ 150-500 (Configuración avanzada)
- ☐ 500-1.000 (Muy avanzado)
- ☐ 1.000+ (Ultra-especializado)

¿Con qué frecuencia revisa y ajusta sus reglas de correlación?

- ☐ Anualmente o menos
- ☐ Cada trimestre
- ☐ Mensualmente
- ☐ Semanalmente
- ☐ Continuamente

P4.7 — MTTR vs MTTR — Vulnerabilidades de Velocidad

¿Cuál es el mayor cuello de botella actual en su ciclo de detección-respuesta?

- ☐ Falta de visibilidad / logs no integrados (problema de MTTR)
- ☐ Falta de analistas para investigar (problema de ambos)
- ☐ Reglas de correlación poco precisas / demasiados falsos positivos (problema de MTTR)
- ☐ Procesos de respuesta lentos (problema de MTTR)
- ☐ Falta de herramientas de orquestación / automatización (problema de MTTR)
- ☐ Falta de documentación de procedimientos (problema de MTTR)
- ☐ No sabemos / no lo hemos analizado (problema de visibilidad)

MÓDULO 5: CAPACITACIÓN EN SEGURIDAD Y CONCIENCIACIÓN

P5.1 — Programa de Capacitación en Seguridad

¿Realiza su organización capacitación en seguridad de la información?

- ☐ No; sin programa formalizado
- ☐ Sí, capacitación genérica anual
- ☐ Sí, capacitación anual diferenciada por rol
- ☐ Sí, capacitación regular (mínimo semestral) diferenciada y adaptada a riesgos
- ☐ Sí, programa integral con capacitación continua, microlearning y aprendizaje basado en incidentes

P5.2 — Audiencias de Capacitación (Coverage)

¿Qué audiencias están cubiertas por programa de capacitación?

Audiencia	Cobertura (%)	Frecuencia	Contenido Principal
Todos los empleados	__%	___/año	Concienciación general
Personal IT	__%	___/año	Administración segura
Desarrolladores	__%	___/año	Codificación segura, OWASP
Ejecutivos/Directores	__%	___/año	Gobernanza, riesgos
Personal de datos (DPOs, custodios)	__%	___/año	GDPR, privacidad
Personal de respuesta a incidentes	__%	___/año	Investigación, contención
Personal de seguridad física	__%	___/año	Acceso, vigilancia
Contratistas/ Proveedores	__%	___/año	Obligaciones contractuales

P5.3 — Metodología de Capacitación

¿Qué métodos de capacitación utiliza?

- ☐ Presencial (aulas, sesiones en vivo)
- ☐ E-learning asincrónico (cursos en línea autoadministrados)
- ☐ Microlearning (píldoras de 5-10 minutos)
- ☐ Gamificación (desafíos, puntos, tablas de posiciones)
- ☐ Simulaciones de phishing
- ☐ Social engineering testado (llamadas, pretexting)
- ☐ Red team exercises
- ☐ Aprendizaje basado en incidentes (post-breach, post-evento)
- ☐ Capacitación de proveedores / terceros
- ☐ Todos los anteriores; programa integral

P5.4 — Indicadores de Efectividad de Capacitación

¿Mide la efectividad de su programa de capacitación?

- ☐ No; asumimos que completar = aprendizaje
- ☐ Sí, solo tasa de finalización (% completó el curso)
- ☐ Sí, tasa de finalización + evaluaciones post-curso
- ☐ Sí, tasa de finalización + evaluaciones + cambio de comportamiento (phishing report rate, incident attribution)
- ☐ Sí, medición integral con ROI cuantificado

P5.5 — KPIs de Concienciación en Seguridad

¿Cuáles son sus métricas actuales de efectividad?

KPI	Línea Base	Objetivo
Tasa de finalización de capacitación (%)	__%	>95%
Phishing click rate (% clics en simulación)	__%	<5%
Phishing report rate (% reportan phishing)	__%	>25%
Tiempo promedio a reportar (minutos)	—	<15
Cambio en incidents attributable a error humano (YoY)	__%	Decrecimiento
Satisfacción con capacitación (encuesta)	__/10	>7/10
Retención de conocimiento (evaluación post-curso)	__%	>70%

P5.6 — Políticas y Comunicaciones de Seguridad

¿Dispone de políticas de seguridad documentadas y comunicadas?

- ☐ No; sin políticas documentadas
- ☐ Sí, políticas documentadas pero no ampliamente comunicadas
- ☐ Sí, políticas documentadas, comunicadas una sola vez (onboarding)
- ☐ Sí, políticas documentadas, comunicadas regularmente (mensual o trimestral)
- ☐ Sí, políticas documentadas, vivas (continuamente actualizadas), comunicadas frecuentemente con ejemplos de incidentes

¿Cuáles de las siguientes políticas están documentadas?

- ☐ Política de Seguridad General / Marco
- ☐ Política de Acceso y Autenticación (incluida MFA)
- ☐ Política de Gestión de Contraseñas
- ☐ Política de Uso Aceptable (Internet, email, dispositivos)
- ☐ Política de Teletrabajo / Trabajo Remoto
- ☐ Política de BYOD (Bring Your Own Device)
- ☐ Política de Dispositivos Móviles
- ☐ Política de Datos Sensibles / Clasificación
- ☐ Política de Privacidad / GDPR
- ☐ Política de Respuesta a Incidentes
- ☐ Política de Continuidad de Negocio / Disaster Recovery
- ☐ Política de Seguridad Física / Control de Acceso
- ☐ Política de Terceros / Proveedores
- ☐ Política de Cumplimiento Normativo
- ☐ Otra (describir): _____

P5.7 — Recursos Dedicados a Capacitación

¿Cuánto personal está dedicado a capacitación en seguridad?

Rol	FTE	Horas/Semana
Responsable de Capacitación (CSO, Security Manager)		
Especialistas en Contenido		
Personal de Entrega (Facilitadores)		
Personal de Soporte Técnico (LMS)		
Total		

¿Cuál es el presupuesto anual dedicado a capacitación de seguridad?

- ☐ <€10.000 (Mínimo)
- ☐ €10.000-€50.000 (Pequeño)
- ☐ €50.000-€150.000 (Moderado)
- ☐ €150.000-€500.000 (Sustancial)
- ☐ >€500.000 (Significativo)

MÓDULO 6: INDICADORES DE MADUREZ Y RETORNO DE INVERSIÓN (ROI)

P6.1 — Evaluación de Madurez NIST CSF 2.0

¿Cuál es el nivel de madurez actual en cada función NIST CSF? (Autoevaluación)

Función NIST	Descripción	Tier (1-4)	% Cobertura Controles
Govern	Políticas, gobernanza, cultura, roles	—	__%
Identify	Inventario, evaluación de riesgos, contexto	—	__%
Protect	Controles técnicos, acceso, cifrado	—	__%
Detect	Monitoreo, detección de anomalías	—	__%
Respond	Investigación de incidentes, contención	—	__%
Recover	Restauración, business continuity, lecciones aprendidas	—	__%

Explicación de Tiers:

- **Tier 1:** Ad hoc, sin proceso documentado
- **Tier 2:** Procesos documentados, repetibles, responsabilidades asignadas
- **Tier 3:** Procesos integrados en gobernanza, métricas, mejora continua
- **Tier 4:** Optimizado, automatizado, aprendizaje de amenazas integrado

P6.2 — Incidentes de Seguridad: Historial e Impacto

¿Cuántos incidentes de seguridad ha experimentado en los últimos 12 meses?

Categoría	Cantidad	Promedio Coste/Incidente	Coste Total
Malware		€__	€__
Phishing / Spear-phishing		€__	€__
Ransomware		€__	€__
Violación de datos / Data breach		€__	€__
Acceso no autorizado		€__	€__
Incidente de disponibilidad		€__	€__
Incidente por error humano		€__	€__
Otro		€__	€__
TOTAL			€__

P6.3 — Costes Operacionales de Ciberseguridad (CAsPeA)

¿Cuál es su presupuesto anual total de ciberseguridad?

€ _____

¿Cómo se distribuye?

Componente	Coste Anual	% del Total
Personal interno (sueldos + beneficios)	€_____	__%
Servicios gestionados (MSS/SOC outsourced)	€_____	__%
Consultoría externa	€_____	__%
Herramientas/software (licencias)	€_____	__%
Hardware/infraestructura	€_____	__%
Formación y capacitación	€_____	__%
Auditoría externa	€_____	__%
Cumplimiento normativo	€_____	__%
Otro	€_____	__%
TOTAL	€_____	100%

P6.4 — Costes Laborales Desglosados (Metodología CAsPeA)

Personal interno de ciberseguridad dedicado:

Rol	FTE	Salario Anual	Beneficios (%)	Coste Total
CISO / Director		€__	__%	€__
Arquitecto de Seguridad		€__	__%	€__
Analista SIEM/SOC		€__	__%	€__
Especialista Respuesta Incidentes		€__	__%	€__
Administrador IAM / Control Acceso		€__	__%	€__
Especialista OT/ICS		€__	__%	€__
Especialista DevSecOps		€__	__%	€__
Responsable Concienciación		€__	__%	€__
Personal Cumplimiento / Auditoría		€__	__%	€__
Otra categoría		€__	__%	€__
TOTAL FTE / COSTE				€__

Horas dedicadas a actividades de ciberseguridad por personal IT NO dedicado:

Rol (Ej: Admin de sistemas)	FTE Total	% Tiempo a Seguridad	FTE Equivalente
Administradores de sistemas		__%	
Ingenieros de infraestructura		__%	
Personal de base de datos		__%	
Personal de help desk / soporte		__%	
Desarrolladores		__%	

P6.5 — Cálculo de ROI Cuantificado

¿Realiza cálculo formal del ROI de ciberseguridad?

- ☐ No; sin cálculo formalizado
- ☐ Sí, pero cualitativo (beneficios narrativos)
- ☐ Sí, semicuantitativo (reducción relativa de riesgos)
- ☐ Sí, cuantificado (pérdida esperada evitada / inversión)

Si cuantifica ROI, ¿cuál es el modelo utilizado?

- ☐ FAIR (Factor Analysis Information Risk)
- ☐ ALE (Annual Loss Expectancy)
- ☐ Comparación de coste de breach (industria benchmark) vs coste preventivo
- ☐ Propietario interno
- ☐ Otro: _____

P6.6 — Métricas de Prevención de Incidentes

¿Puede estimar cuántos incidentes ha evitado por actividad de seguridad?

Actividad / Control	Incidentes Evitados (Est.)	Coste Evitado (Est.)
Filtrado de phishing		€__
Vulnerabilidades parcheadas		€__
Detección por SIEM		€__
Control de acceso (prevención de acceso no aut.)		€__
Respuesta a incidentes (contención rápida)		€__
Capacitación en seguridad		€__
Otra		€__

P6.7 — Puntuación de Madurez General

¿Cómo se autoevalúa globalmente en madurez de ciberseguridad?

- ☐ Nivel 1 (Inicial): Procesos ad hoc, sin documentación formal, sin métricas
- ☐ Nivel 2 (Repetible): Procesos documentados, repetibles, responsables asignados
- ☐ Nivel 3 (Definido): Procesos integrados en gobernanza corporativa, métricas básicas, mejora continua
- ☐ Nivel 4 (Gestionado): Métricas avanzadas, automatización, gestión de capacidad, alineación con riesgos de negocio
- ☐ Nivel 5 (Optimizado): Mejora continua proactiva, aprendizaje de amenazas integrado, innovación

MÓDULO 7: COMENTARIOS Y OBSERVACIONES FINALES

P7.1 — Mayores Desafíos

¿Cuáles son los tres mayores desafíos actuales de ciberseguridad de su organización?

7.

8.

9.

P7.2 — Prioridades Estratégicas para los Próximos 12 Meses

¿Cuáles son sus principales iniciativas de seguridad planificadas?

- ☐ Implementación de SIEM o mejora del existente
- ☐ Programa de gestión de vulnerabilidades formalizado
- ☐ Respuesta a cumplimiento NIS2
- ☐ Implementación de MFA / Zero Trust
- ☐ Fortalecimiento de capacitación en seguridad
- ☐ Mejora de respuesta a incidentes
- ☐ Auditoría ISO 27001
- ☐ Migración a cloud seguro
- ☐ Fortalecimiento de seguridad OT/ICS
- ☐ Mejora de continuidad de negocio
- ☐ Otra (describir): ____

P7.3 — Información de Contacto

Encuestado: ____

Cargo: ____

Organización: ____

Email: ____

Teléfono (opcional): ____

Fecha de encuesta: ____

AGRADECIMIENTO Y CONFIDENCIALIDAD

Agradecemos sinceramente su participación en esta encuesta. Sus respuestas son confidenciales y se utilizarán únicamente para:

- Análisis agregado a nivel sectorial
- Benchmarking anonimizado
- Generación de informes de madurez
- Investigación académica

Los datos individuales no serán compartidos sin consentimiento explícito.

Fin de la Encuesta CRA-Cyber v2.1

Documentación complementaria: Guía Metodológica, Plantilla Excel de Cálculo CAsPeA, Mapeo Normativo